avansat

Tehnologii Web

arhitectura serverului Web

supliment

Dr. Sabin Corneliu Buraga – profs.info.uaic.ro/~busaco/

„Lucrurile nu sunt greu de făcut.
Greu este să te pui în starea de-a le face.”

Constantin Brâncuși

Care e arhitectura serverului Web?

HTTP: server Web

Deservește cereri multiple provenite de la clienți pe baza protocolului HTTP

HTTP: server Web

Deservește cereri multiple provenite de la clienți pe baza protocolului HTTP

fiecare cerere e considerată independentă de alta, chiar dacă provine de la același client Web

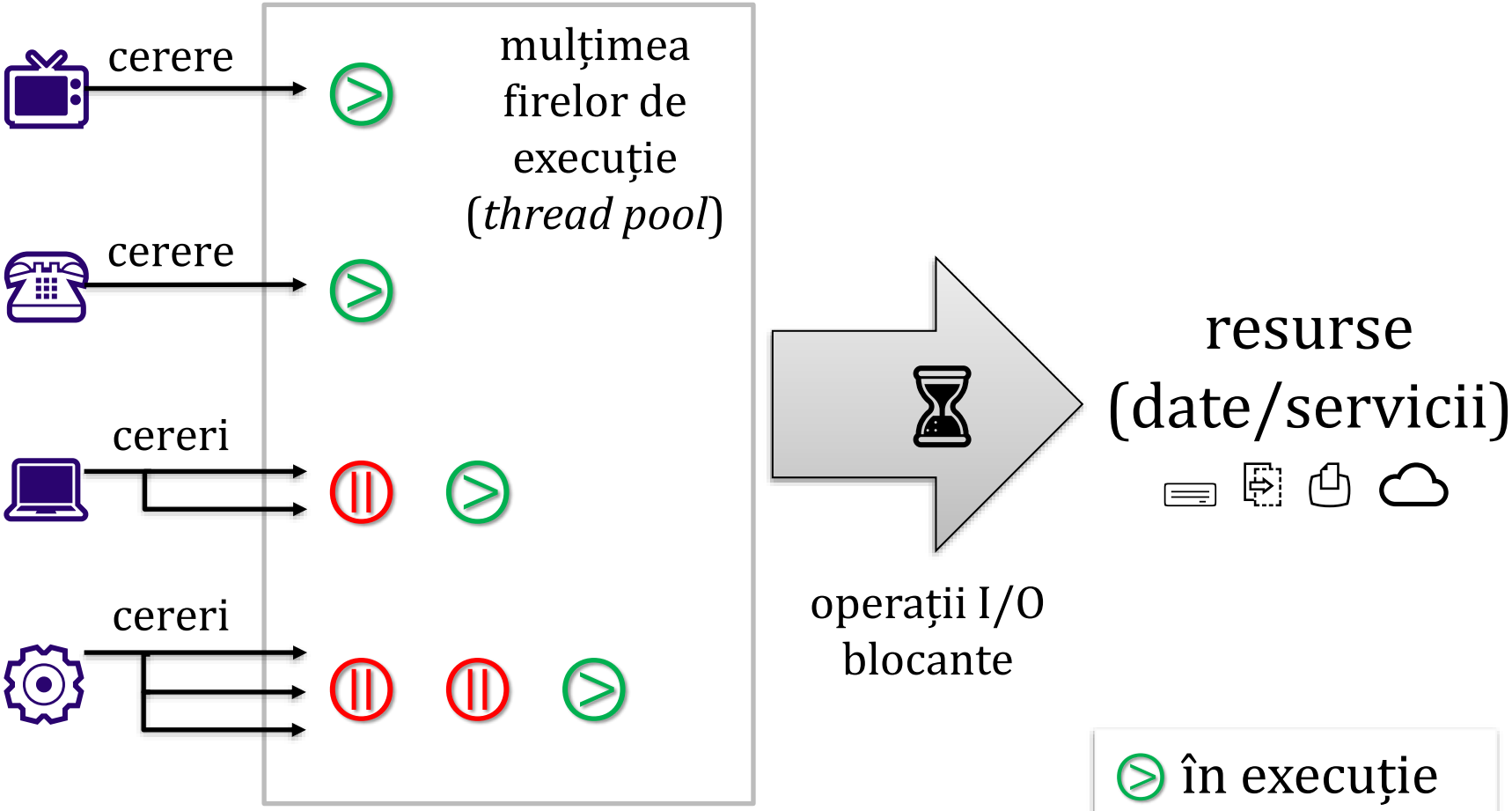
- nu e păstrată starea conexiunii – ***stateless***

HTTP: server Web

Tradițional, implementarea serverului Web este una *pre-forked* sau *pre-threaded*

se creează un număr de procese copil ori fire de execuție (*threads*) la inițializare, fiecare proces/fir interacționând cu un anumit client

server Web clasic



server Web *multi-threaded*

cererile multiple de la diverși clienți nu pot fi deservite simultan (numărul firelor de execuție asociate unui proces este limitat)

HTTP: server Web

Comportamentul serverului poate fi stabilit via diverși parametri (directive) de configurare

HTTP: server Web

Studiu de caz: configurarea serverului Apache
(lansat în 1995; cel mai popular server Web)
httpd.apache.org

configurația globală prin fișierul **httpd.conf**
implicit, se creează 6 instanțe **httpd**

HTTP: server Web

Studiu de caz: configurarea serverului Apache
(lansat în 1995; cel mai popular server Web)
httpd.apache.org

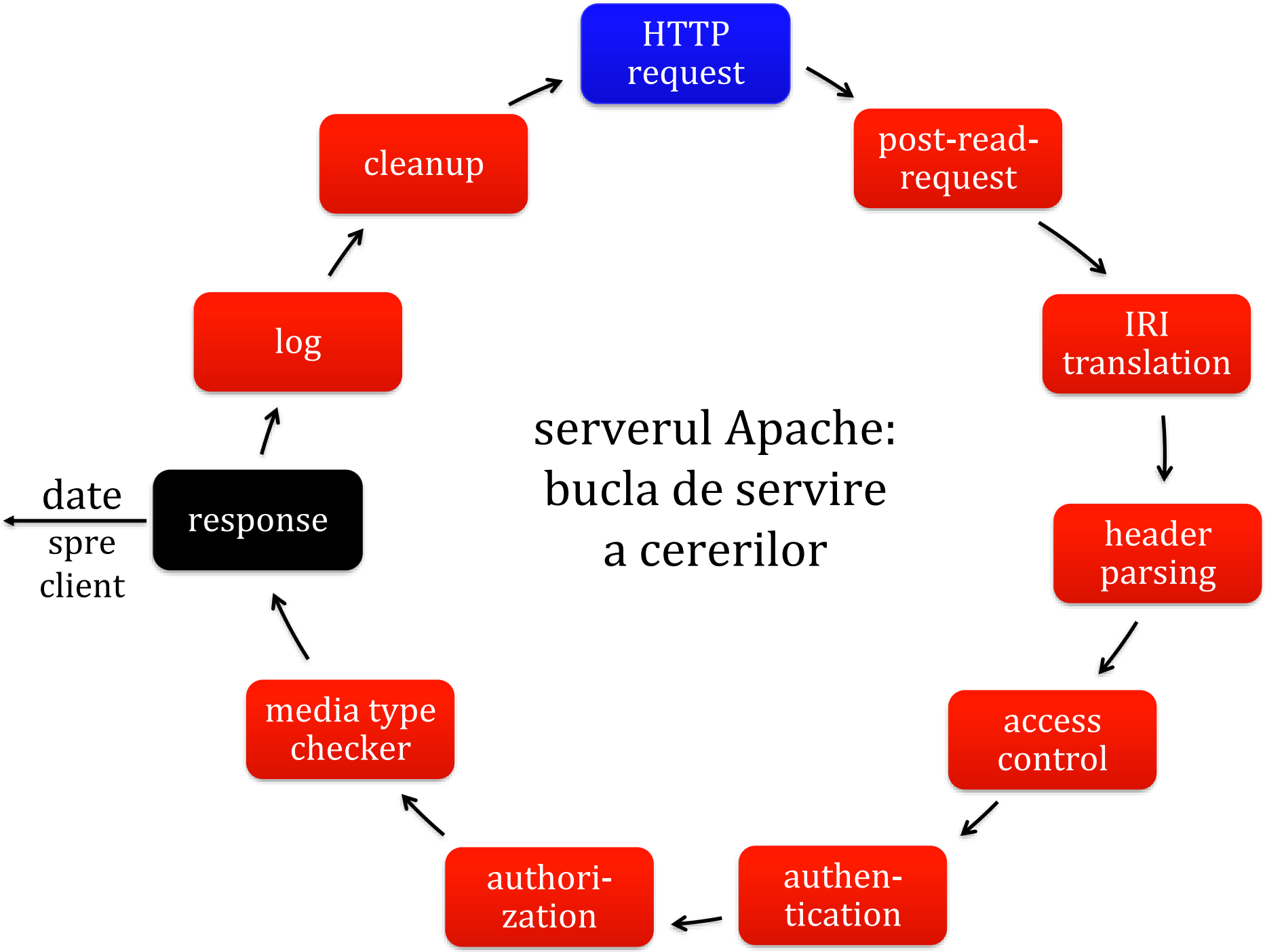
configurația globală prin fișierul **httpd.conf**
implicit, se creează 6 instanțe **httpd**

la nivel de utilizator (per director/URI), se poate configura
via **.htaccess** – vezi și **github.com/phanan/htaccess**

HTTP: server Web

Studiu de caz: configurarea serverului Apache

posibilitatea de a constitui gazde virtuale – *virtual hosting*: același server poate găzdui (rula) mai multe situri Web, având diferite nume de domeniu simbolice


HTTP request
post-read-request
IRI translation
header parsing
access control
authen-tication
authori-zation
media type checker
response
date
spre client
log
cleanup
serverul Apache:
bucla de servire
a cererilor

Uzual, arhitectura serverului Web e modularizată

nucleu (*core*)

+

module implementând funcționalități specifice

Uzual, arhitectura serverului Web e modularizată

nucleu (*core*)

+

module implementând funcționalități specifice

oferă o interfață de programare (API) a modulelor în limbajul C

httpd.apache.org/docs/current/developer/

Uzual, arhitectura serverului Web e modularizată

nucleu (*core*)

+

module implementând funcționalități specifice

lista modulelor Apache oficiale:

httpd.apache.org/docs/current/mod/

Module Apache utilizate frecvent

jurnalizarea cererilor primite de serverul Web

mod_log_config

httpd.apache.org/docs/current/logs.html

Module Apache utilizate frecvent

controlul *cache*-ului – memorarea temporară a datelor pe diverse medii de stocare (*e.g.*, disc)

mod_cache

httpd.apache.org/docs/current/mod/mod_cache.html

Module Apache utilizate frecvent

suport pentru crearea unui *proxy*/*gateway* Web, inclusiv echilibrarea încărcării (*load balancing*), crearea de tuneluri

mod_proxy

httpd.apache.org/docs/current/mod/mod_proxy.html

Module Apache utilizate frecvent

suport pentru transferuri „securizate” via HTTPS pe baza TLS (*Transport Layer Security*) și SSL (*Secure Sockets Layer*) implementate de biblioteca OpenSSL

mod_ssl

httpd.apache.org/docs/current/mod/mod_ssl.html

Module Apache utilizate frecvent

rescrierea adreselor Web – *URL rewritting* – pe baza expresiilor regulate (*e.g.*, simplificarea sintaxei URL-urilor)

mod_rewrite

httpd.apache.org/docs/current/mod/mod_rewrite.html

Module Apache utilizate frecvent

acces restricționat la resurse – suport pentru diverse metode de autentificare și autorizare

mod_auth_basic

mod_auth_digest

mod_authn_core mod_authn_file mod_authn_dbd

mod_authz_core mod_authz_user mod_authz_host

Module Apache utilizate frecvent

suport pentru gestiunea datelor vizând sesiunile Web

mod_session

mod_session_cookie

mod_session_crypto

mod_session_dbd

Module Apache utilizate frecvent

livrarea compresată a datelor (reprezentărilor de resurse)

mod_deflate

mod_brotli

Module Apache utilizate frecvent

suport pentru deservirea cererilor
pe baza protocolului HTTP2

mod_http2

httpd.apache.org/docs/current/mod/mod_proxy_http2.html

Module Apache utilizate frecvent

includerea direct în server a suportului
pentru execuția de programe:

mod_cgi – suport CGI: **httpd.apache.org/docs/current/howto/cgi.html**

mod_php – integrare cu PHP

mod_wsgi – integrare cu Python: **modwsgi.readthedocs.io/en/develop/**

altele: **mod_perl mod_ruby mod_lua mod_mono**

Module Apache utilizate frecvent

managementul conexiunilor la
sisteme de baze de date relaționale (via SQL)
recurgându-se la APR – *Apache Portable Runtime*

mod_dbd

httpd.apache.org/docs/current/mod/mod_dbd.html
apr.apache.org

Module Apache utilizate frecvent

deservirea cererilor via fire de execuție multiple
(*hybrid multi-process multi-threaded*)
mod_worker

httpd.apache.org/docs/current/mod/worker.html

Studiu de caz: securizarea serverului Apache

aspecte esențiale

Studiu de caz: securizarea serverului Apache

aspecte esențiale

activități de tip **DevOps**: aspecte privind dezvoltarea aplicațiilor Web (Dev – *Development*)
+ operațiuni de administrare (Ops – *Operations*)

de studiat:
Apache Security Hardening Guide
www.apachecon.eu

Studiu de caz: securizarea serverului Apache

actualizarea permanentă a serverului Web
și a modulelor sale

Studiu de caz: securizarea serverului Apache

instalarea de module ce previn atacuri de securitate

mod_security – *firewall*

www.modsecurity.org

Studiu de caz: securizarea serverului Apache

instalarea de module ce previn atacuri de securitate

mod_security – *firewall*

www.modsecurity.org

de studiat și regulile stipulate de
OWASP ModSecurity Core Rule Set (CRS)
coreruleset.org
github.com/SpiderLabs/owasp-modsecurity-crs

Studiu de caz: securizarea serverului Apache

instalarea de module ce previn atacuri de securitate

mod_evasive – previne refuzuri de servicii:
(D)DoS – (*Distributed*) *Denial of Services*

www.linode.com/docs/web-servers/apache-tips-and-tricks/modevasive-on-apache/

Studiu de caz: securizarea serverului Apache

eliminarea modulelor care nu sunt esențiale

mod_autoindex
mod_dav
mod_info
mod_status
...

Studiu de caz: securizarea serverului Apache

rularea serverului ca utilizator cu drepturi minime,
cu limitarea accesului la resursele sistemului

de experimentat modulul **mod_ratelimit**
httpd.apache.org/docs/current/mod/mod_ratelimit.html

Studiu de caz: securizarea serverului Apache

rularea serverului ca utilizator cu drepturi minime,
cu limitarea accesului la resursele sistemului

ajustarea – în fișierul **httpd.conf** –
a directivelor de configurare:

KeepAlive KeepAliveTimeout LimitRequestBody LimitRequestFields LimitRequestFieldSize LimitRequestLine LimitXMLRequestBody MaxClients MaxKeepAliveRequests MaxRequestWorkers RequestReadTimeout TimeOut

Studiu de caz: securizarea serverului Apache

restrângerea permisiunilor implicite
pentru diverse directoare:

/

/var/www/html (directorul *root* al sitului)

directoarele (**public_**)**html/** ale utilizatorilor

vezi directiva Require

httpd.apache.org/docs/2.4/howto/access.html

Studiu de caz: securizarea serverului Apache

„imunizarea” fișierelor de configurare importante

inhibarea modificării acestora
via **permisiuni**
sau
folosind politici de acces
de tip **RBAC** (***Role-Based Access Control***)

Studiu de caz: securizarea serverului Apache

rularea Apache într-un *chroot jail*

izolarea serverului Web de sistemul gazdă pe care rulează

- *sandboxing*

Studiu de caz: securizarea serverului Apache

eliminarea creării „semnăturii” serverului
pentru resursele oferite:

ServerSignature Off

ServerTokens Prod

Studiu de caz: securizarea serverului Apache

eliminarea creării „semnăturii” serverului
pentru resursele oferite:
ServerSignature Off
ServerTokens Prod

un posibil atacator poate inspecta mesajul de răspuns HTTP pentru a obține versiunea curentă a serverului Web
Server: Apache/2.4.35 (IUS) OpenSSL/1.0.2k-fips mod_fcgid/2.3.9 PHP/7.2.14
versus
Server: Apache

Studiu de caz: securizarea serverului Apache

recurgerea la modulul **mod_ssl**
pentru oferirea de conexiuni HTTPS

Studiu de caz: securizarea serverului Apache

verificarea/ajustarea permisiunilor fișierelor publice

httpd.apache.org/docs/2.4/misc/security_tips.html#serverroot

Studiu de caz: securizarea serverului Apache

limitarea/inhibarea *upload*-urilor de fișiere

la nivel de server Web
vezi directiva de configurare FilesMatch
httpd.apache.org/docs/2.4/mod/core.html#filesmatch
și/sau
pentru un server de aplicații Web – *e.g.*, PHP
www.php.net/manual/en/ini.core.php#ini.file-uploads

Studiu de caz: securizarea serverului Apache

limitarea/interzicerea folosirii **.htaccess**
de către utilizatorii obișnuiți

amănunte la
httpd.apache.org/docs/current/howto/htaccess.html

Studiu de caz: securizarea serverului Apache

interzicerea accesului la tabela **users** la MariaDB/MySQL

mariadb.com/kb/en/mysqluser-table/

dev.mysql.com/doc/refman/en/grant-tables.html

idem, pentru alte servere de baze de date

Studiu de caz: securizarea serverului Apache

configurarea serverelor de aplicații să nu trimită *browser*-ului mesajele de eroare

e.g., la PHP: display_errors off

de parcurs și
www.php.net/manual/en/function.error-reporting.php

Studiu de caz: securizarea serverului Apache

actualizarea sitului doar prin metode securizate:
SSH (*Secure SHell network protocol*)
www.snailbook.com/protocols.html

pe baza SSH, se pot folosi:
SCP (*Secure Copy Protocol*)
SFTP (*Secure File Transfer Protocol*)

Studiu de caz: securizarea serverului Apache

pentru alte reguli de bună practică, a se consulta
httpd.apache.org/docs/2.4/misc/security_tips.html

HTTP: server Web – resurse

Apache Tutorials:
httpd.apache.org/docs/current/howto/

Apache @ Digital Ocean:
www.digitalocean.com/community/tags/apache

Apache / ModSecurity Tutorials:
www.netnea.com/cms/apache-tutorials/

HTTP: server Web

Alternativ, pot fi folosite strategii asincrone (non-blocante) adoptând un unic fir de execuție (*single threaded*)

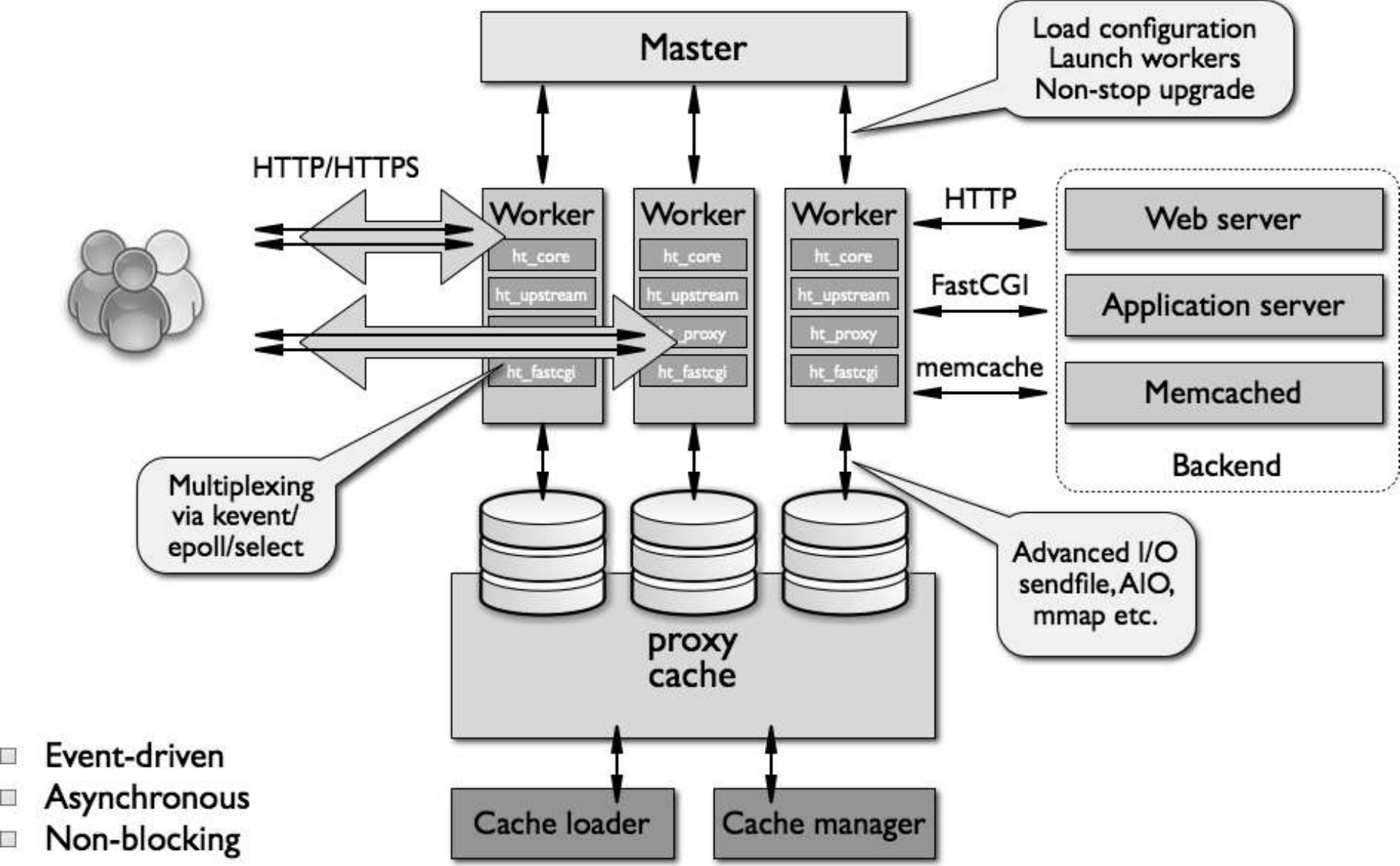
HTTP: server Web

Alternativ, pot fi folosite strategii asincrone (non-blocante) adoptând un unic fir de execuție (*single threaded*)

exemplu de referință:

NGINX

www.nginx.com/blog/inside-nginx-how-we-designed-for-performance-scale/



arhitectura generală inițială a serverului NGINX

www.aosabook.org/en/nginx.html

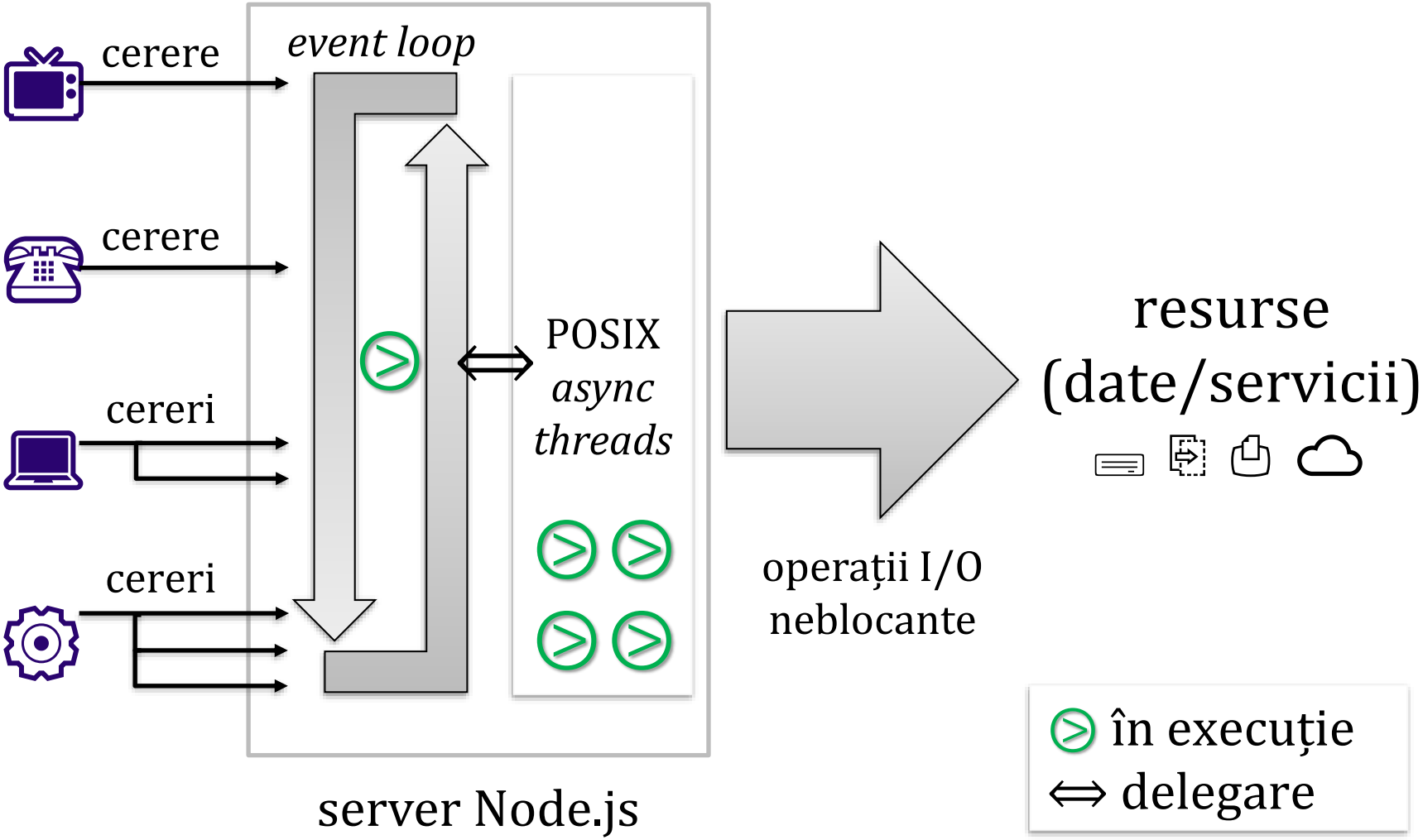
HTTP: server Web

Alternativ, pot fi folosite strategii asincrone (non-blocante) adoptând un unic fir de execuție (*single threaded*)

programatorul își poate crea propriul server Web conceput în limbajul JavaScript (ECMAScript):
Node.js

vezi viitorul supliment

Node.js

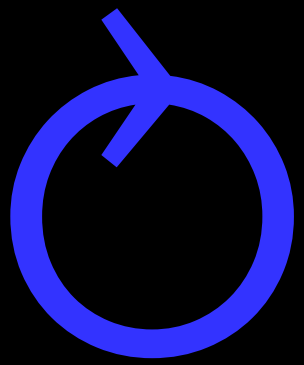


cererile multiple de la diverși clienți pot fi deservite simultan

HTTP: server Web – alte soluții

Apache Tomcat
Caddy
Eclipse Jetty
lighttpd
Microsoft IIS (*Internet Information Services*)
Mongoose
NaviServer
thttpd
Yaws (*Yet Another Web Server*)

rezumat



arhitectura generică a unui server Web
exemplificare: Apache HTTP Server